

Scaling the Integration

MISP Integration Workshop

Why query-per-event doesn't scale

Tune the trigger

Cache MISP responses

Pull model with a CDB list

Insulate the MISP instance

The starting point

query-per-event integration.

- Every matching alert is handed to `custom-misp.py`.
- The script makes a **synchronous MISP REST call** per IOC.
- Fine for a few lab agents — it does **not** scale.

Lookup volume tracks **alert** volume, not the number of real matches.

Why it breaks down

A single MISP instance on the hot path of every event.

- Every FIM and Suricata record becomes one+ MISP queries — mostly **no match**.
- A few hundred agents can produce **thousands of lookups/second**.
- Under load: rising API latency, a backed-up `wazuh-integratord` queue, dropped alerts, and MISP going unresponsive for analysts.

Fixes go cheapest → most robust; in production you combine several.

Reduce the lookups

The cheapest win is not making the query at all.

- **Tighten the trigger** — narrow the `<group>` filter; only high-value alerts.
- **Reduce noise at the source** — scope FIM directories, tune Suricata logging.
- **Prefer specific IOC types** — hashes/domains over raw IPs; drop what you don't act on.

Lowers load, but keeps the per-event, single-instance dependency.

Cache MISP responses

The same IOCs recur constantly across agents.

- Add a local cache (Redis or on-disk KV) in front of the MISP call.
- **Cache negative results too** — they dominate — with a short TTL.
- Or put a **caching reverse proxy** in front of `/attributes/restSearch`.

A flood of lookups for one benign value hits MISP once, not thousands of times.

Switch to a pull model (recommended)

Export IOCs from MISP; match locally on the manager with a CDB list.

- Removes MISP from the hot path — matching is an **in-memory lookup**.
- **Zero API calls per event**, no matter how many agents you run.
- Reuse the PyMISP export (`get_iocs_csv.py`) from cron every 15–30 min.

Trade-off: detections are only as fresh as your last sync.

CDB list in practice

Export → reference in a rule → compile & reload.

```
<rule id="100700" level="12">  
  <list field="data.dest_ip"  
    lookup="address_match_key">etc/lists/misp-ip-iocs</list>  
  <description>MISP IoC (offline) - $(data.dest_ip) is known-malicious</description>  
</rule>
```

```
/var/ossec/bin/wazuh-makelists  
systemctl restart wazuh-manager
```

Keep query-per-event for the few low-volume, high-value alert groups.

7 / 10

Insulate the MISP instance

Treat MISP as a shared production service.

- Give the integration a **dedicated API user** — rate-limit, audit, revoke.
- Serve API traffic via a **caching proxy**; use a **read-only replica** for lookups.
- Publish IOCs as a **feed/export** that consumers pull, not live API hits.

Keep the primary instance responsive for analysts on the web UI.

If lookup volume scales with agent count, you have a scaling problem.

Move matching off the per-event path — keep live queries for where up-to-the-second context justifies the call.

Questions?